Chương 6
Bảo mật và phân quyền

GVHD: TS. Phan Thị Thể

FIT – HCM-UTE

Email: thept@hcmute.edu.vn

Nội dung chương 6

1. Giới thiệu về bảo mật cơ sở dữ liệu
2. Các mức bảo mật
3. Kiểm soát truy cập
4. Gán và gỡ bỏ quyền (GRANT / REVOKE / DENY)
5. Gán và gỡ bỏ quyền trên View
6. Phân quyền dựa trên Role (Role-Based Authorization)
7. Bài tập

1. Giới thiệu về bảo mật cơ sở dữ liệu

1. Giới thiệu về bảo mật cơ sở dữ liệu

- Bảo mật cơ sở dữ liệu (Database Security) là
  - tập hợp các biện pháp, chính sách và cơ chế kỹ thuật nhằm bảo vệ dữ liệu lưu trữ trong CSDL khỏi các hành vi truy cập, sửa đổi, phá hoại hoặc tiết lộ trái phép, đồng thời vẫn đảm bảo dữ liệu sẵn sàng phục vụ cho những người dùng hợp lệ.
  - Đây là một phần không thể tách rời trong quản trị CSDL, vì CSDL thường lưu trữ những thông tin có giá trị cao (tài chính, khách hàng, y tế, bí mật kinh doanh...).

1. Giới thiệu về bảo mật cơ sở dữ liệu

- **Ba mục tiêu cốt lõi (mô hình CIA)**



Mục tiêu	Ý nghĩa	Ví dụ vi phạm
Confidentiality (Tính bí mật)	Chỉ người dùng được ủy quyền mới xem được dữ liệu	Nhân viên xem lương của người khác khi không có quyền
Integrity (Tính toàn vẹn)	Dữ liệu không bị sửa đổi trái phép hoặc sai lệch	Sửa điểm thi trái phép, xóa giao dịch ngân hàng
Availability (Tính sẵn sàng)	Hệ thống luôn phục vụ được người dùng hợp lệ khi cần	Tấn công từ chối dịch vụ (DoS) làm sập server CSDL

1. Giới thiệu về bảo mật cơ sở dữ liệu

- **Các mối đe dọa thường gặp**
  - Truy cập trái phép (Unauthorized access): người dùng không có quyền vẫn đọc/ghi được dữ liệu.
  - Lạm quyền (Privilege abuse): người dùng có quyền hợp lệ nhưng sử dụng sai mục đích.
  - SQL Injection: chèn mã SQL độc hại thông qua đầu vào của ứng dụng để vượt qua kiểm soát truy cập.
  - Nghe lén trên đường truyền (Eavesdropping): dữ liệu bị chặn khi truyền giữa client và server.
  - Mất dữ liệu do sự cố phần cứng, thiên tai, lỗi con người.
  - Tấn công từ nội bộ (Insider threat): nhân viên/DBA lạm dụng quyền quản trị.

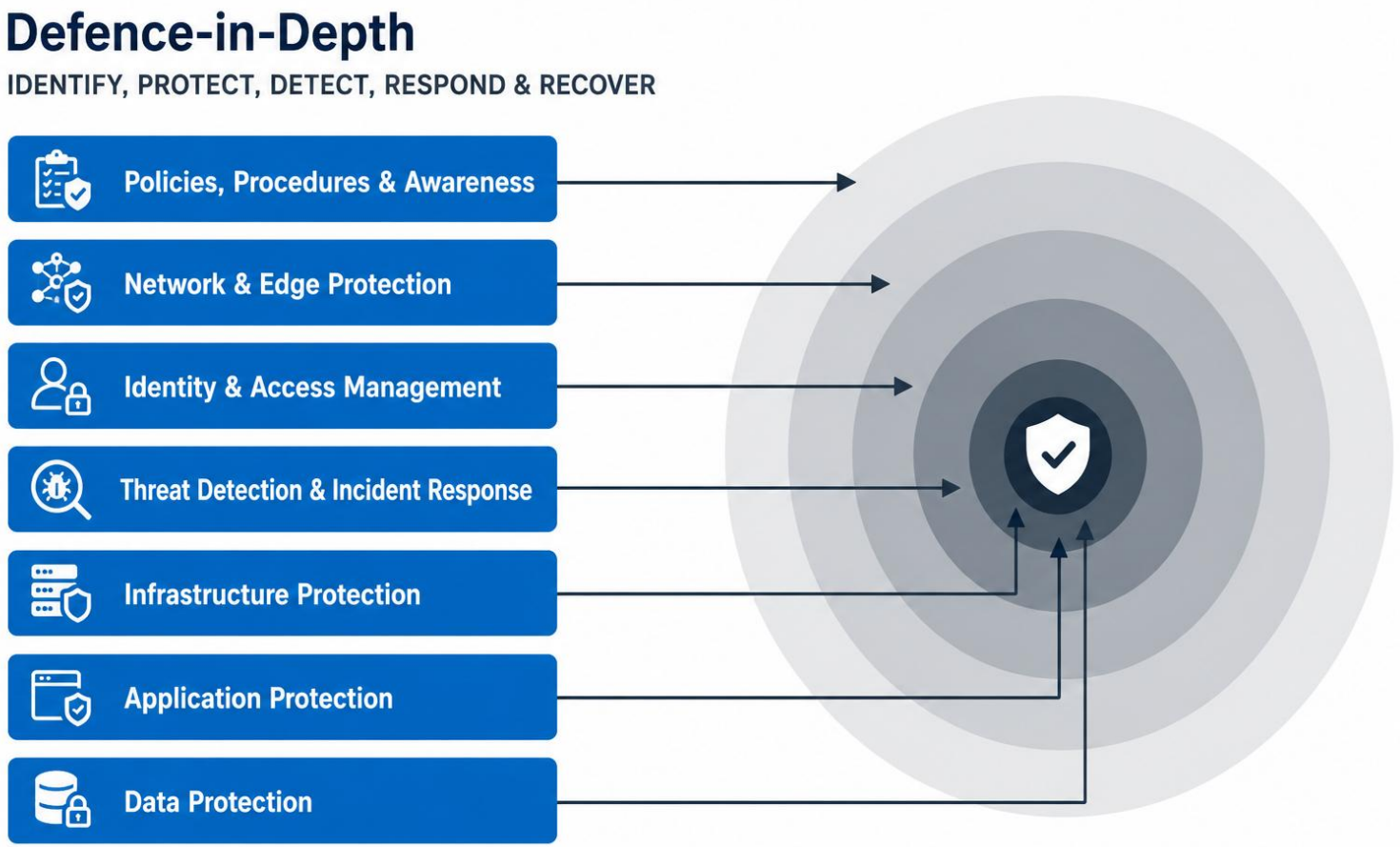
1. Giới thiệu về bảo mật cơ sở dữ liệu

- **Trách nhiệm của người quản trị CSDL (DBA)**
  - Thiết lập tài khoản đăng nhập (login/user) và cấp phát quyền tối thiểu cần thiết (Principle of Least Privilege).
  - Xây dựng các vai trò (role) và nhóm quyền hợp lý theo chức năng công việc.
  - Giám sát, ghi log (audit) các hoạt động truy cập nhạy cảm.
  - Mã hóa dữ liệu nhạy cảm (encryption at rest, encryption in transit – TDE, Always Encrypted trong SQL Server).
  - Sao lưu – phục hồi (backup & restore) để đảm bảo tính sẵn sàng.
- **Nguyên tắc vàng**
  - Principle of Least Privilege (nguyên tắc đặc quyền tối thiểu): mỗi tài khoản chỉ nên được cấp đúng những quyền cần thiết để thực hiện công việc của mình, không hơn không kém.

2. Các mức bảo mật

2. Các mức bảo mật

- Bảo mật CSDL không chỉ nằm ở lệnh GRANT/REVOKE mà là một hệ thống phòng thủ nhiều lớp (defense in depth), bao gồm các mức từ vật lý đến logic bên trong CSDL.



2. Các mức bảo mật

- Các mức bảo mật tổng quát

Mức	Nội dung bảo vệ	Biện pháp tiêu biểu
Vật lý (Physical)	Máy chủ, ổ đĩa, phòng máy	Kiểm soát ra vào, camera, khóa tủ rack
Con người (Human)	Nhân sự vận hành hệ thống	Xét lý lịch, phân quyền theo chức danh, đào tạo an toàn thông tin
Hệ điều hành (OS)	Tài nguyên hệ thống bên dưới DBMS	Tài khoản OS, quyền file, tường lửa hệ điều hành
Mạng (Network)	Đường truyền dữ liệu	Firewall, VPN, mã hóa TLS/SSL, giới hạn IP kết nối
Hệ quản trị CSDL (DBMS)	Đối tượng bên trong CSDL	Login, User, Role, GRANT/REVOKE/DENY, View, mã hóa dữ liệu

2. Các mức bảo mật

- **Các mức bảo mật cụ thể trong SQL Server**
- SQL Server tổ chức bảo mật theo mô hình phân cấp (security hierarchy) gồm nhiều phạm vi (scope):
  - Mức Server (Server-level / Instance): quản lý Login, Server Role, quyền tạo/xóa database, cấu hình instance.
  - Mức Database: quản lý User, Database Role, quyền trên các đối tượng trong một CSDL cụ thể.
  - Mức Schema: nhóm các đối tượng (table, view, procedure...) theo lược đồ (schema), có thể cấp quyền trên toàn schema.
  - Mức Object/Column: quyền chi tiết trên từng bảng, view, thủ tục, hàm, thậm chí từng cột.

2. Các mức bảo mật

Các mức bảo mật cụ thể trong SQL Server

- **Sơ đồ phân cấp bảo mật SQL Server**

```
Server (Instance)
 ├── Login (tài khoản đăng nhập server: SQL Login / Windows Login)
 │       └── Server Role (sysadmin, dbcreator, securityadmin, ...)
 │
 └── Database
         └── User (ánh xạ 1-1 với 1 Login trong database đó)
                 └── Database Role (db_owner, db_datareader, role tự tạo...)
                         └── Schema (dbo, sales, hr, ...)
                                 └── Object (Table, View, Stored Procedure, Function, Column)
```

3. Kiểm soát truy cập

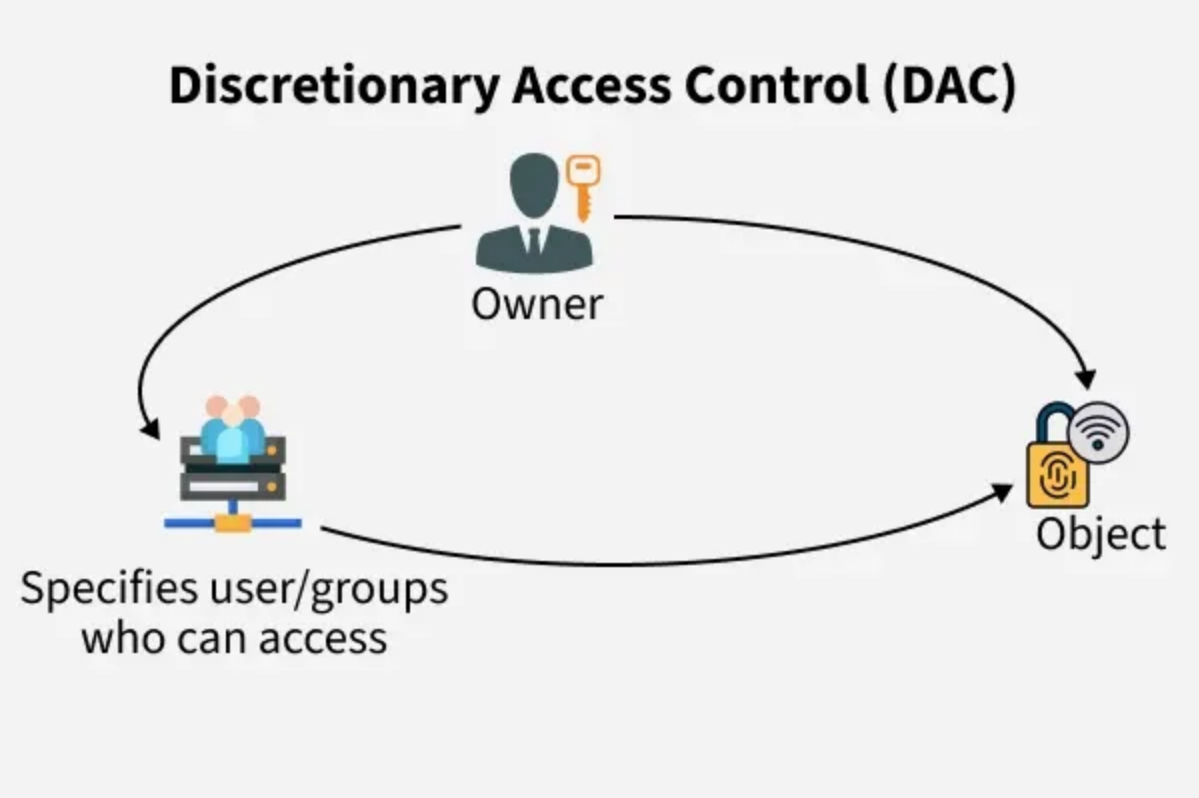
3. Kiểm soát truy cập

- **Khái niệm**
- Kiểm soát truy cập là cơ chế xác định ai (subject) được phép thực hiện thao tác gì (action) trên đối tượng nào (object) trong CSDL. Quá trình này gồm hai bước:
  - Authentication (Xác thực): xác minh danh tính người dùng (thường qua login/password, Windows Authentication, hoặc chứng thực Active Directory).
  - Authorization (Cấp quyền/ủy quyền): xác định người dùng đã xác thực được phép làm gì trên CSDL.

3. Kiểm soát truy cập

Các mô hình kiểm soát truy cập

- ***DAC – Discretionary Access Control (Kiểm soát truy cập tùy quyền)***



3. Kiểm soát truy cập

Các mô hình kiểm soát truy cập

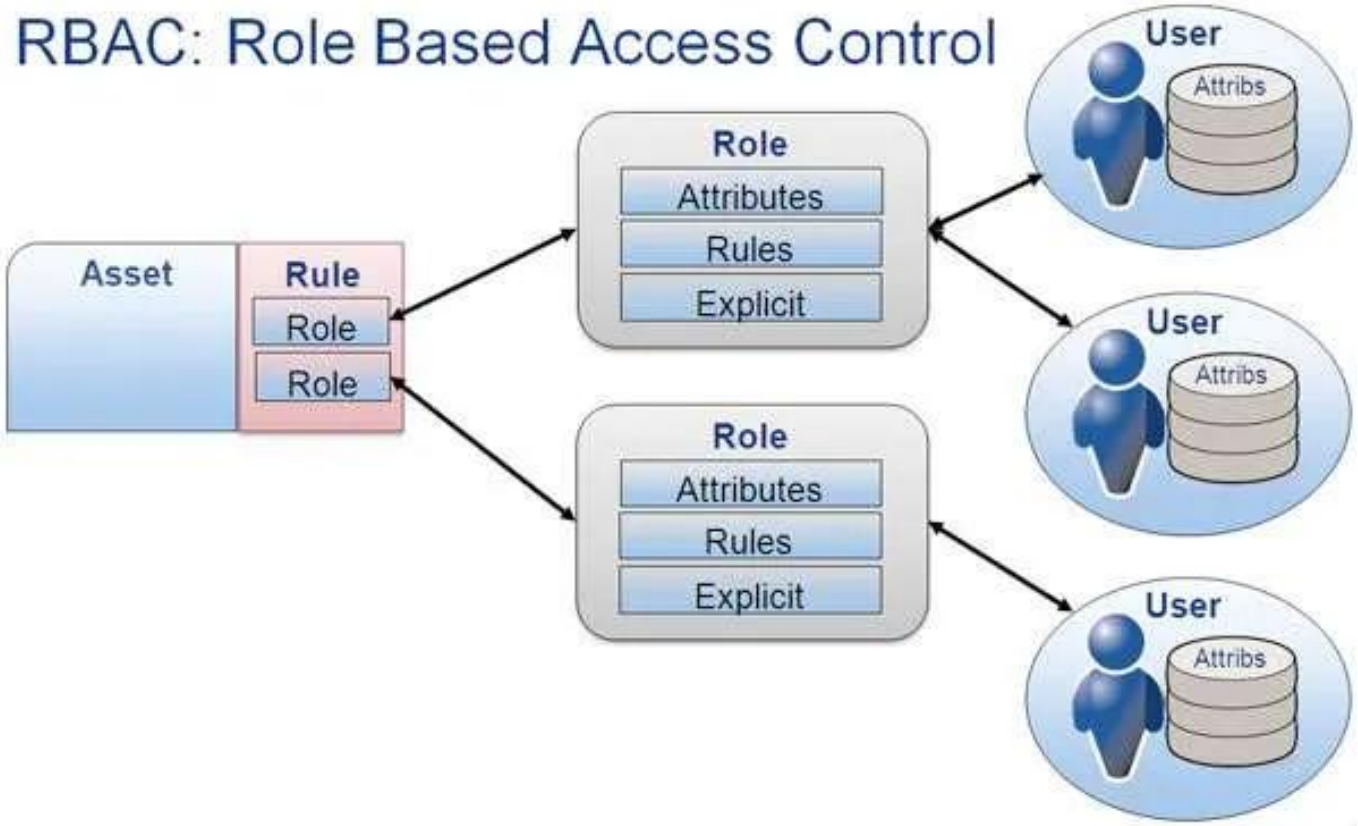
- ***MAC – Mandatory Access Control (Kiểm soát truy cập bắt buộc)***



3. Kiểm soát truy cập

Các mô hình kiểm soát truy cập

- ***RBAC – Role-Based Access Control (Kiểm soát truy cập theo vai trò)***



3. Kiểm soát truy cập

- Xác thực trong SQL Server (Authentication Modes)

Chế độ	Mô tả
Windows Authentication	Sử dụng tài khoản Windows/Active Directory để đăng nhập; SQL Server tin tưởng vào việc xác thực của Windows.
SQL Server Authentication	SQL Server tự quản lý login/password riêng, độc lập với hệ điều hành.
Mixed Mode	Cho phép cả hai cơ chế trên cùng hoạt động.

3. Kiểm soát truy cập

- Các loại quyền (Permission) phổ biến

Nhóm quyền	Ví dụ quyền	Ý nghĩa
Quyền trên dữ liệu (DML)	SELECT, INSERT, UPDATE, DELETE	Đọc/ghi dữ liệu trong bảng, view
Quyền trên cấu trúc (DDL)	CREATE TABLE, ALTER, DROP	Tạo/sửa/xóa đối tượng CSDL
Quyền thực thi	EXECUTE	Chạy stored procedure, function
Quyền quản trị	CONTROL, ALTER ANY LOGIN, ALTER ANY USER	Quản trị server/database
Quyền tham chiếu	REFERENCES	Tạo khóa ngoại tham chiếu đến bảng khác

4. Gán và gỡ bỏ quyền (GRANT / REVOKE / DENY)

4. Gán và gỡ bỏ quyền (GRANT / REVOKE / DENY)

- **Cú pháp tổng quát trong SQL Server (T-SQL)**

```
-- Gán quyền
GRANT <danh_sách_quyền> ON <đối_tượng> TO <user | role> [WITH
  GRANT OPTION];

-- Gỡ bỏ quyền đã gán (không cấm, chỉ hủy hiệu lực của GRANT
  trước đó)
REVOKE <danh_sách_quyền> ON <đối_tượng> FROM <user | role>;

-- Cấm tường minh (ưu tiên cao hơn GRANT)
DENY <danh_sách_quyền> ON <đối_tượng> TO <user | role>;
```

4. Gán và gỡ bỏ quyền (GRANT / REVOKE / DENY)

- Ba lệnh cốt lõi:

Lệnh	Ý nghĩa	Ghi chú
GRANT	Cấp quyền cho user/role	Có thể kèm WITH GRANT OPTION để cho phép người nhận cấp lại quyền cho người khác
DENY	Từ chối tường minh, cấm quyền dù có được GRANT từ nơi khác	DENY luôn thắng GRANT (ưu tiên cao nhất)
REVOKE	Thu hồi quyền đã GRANT hoặc đã DENY trước đó (đưa về trạng thái trung lập)	Không đồng nghĩa với cấm; chỉ đơn giản là gỡ bản ghi quyền

- **Thứ tự ưu tiên khi có xung đột**
  - DENY > GRANT > (mặc định không có quyền). Nếu một user vừa được GRANT một quyền trực tiếp, vừa được GRANT quyền đó qua Role, nhưng lại bị DENY quyền đó (trực tiếp hoặc qua một Role khác mà user tham gia) thì DENY sẽ thắng và user KHÔNG có quyền đó.

4. Gán và gỡ bỏ quyền (GRANT / REVOKE / DENY)

- **Ví dụ minh họa**
- Giả sử ta có CSDL QuanLyBanHang với các bảng KhachHang, DonHang, SanPham. Cần tạo tài khoản cho nhân viên bán hàng tên NhanVien1.
- ***Bước 1 – Tạo Login ở mức Server***

```
USE master;
CREATE LOGIN NhanVien1 WITH PASSWORD = 'MatKhau@123', CHECK_POLICY = ON;
```

- ***Bước 2 – Tạo User ở mức Database, ánh xạ với Login***

```
USE QuanLyBanHang;
CREATE USER NhanVien1 FOR LOGIN NhanVien1;
```

- ***Bước 3 – Cấp quyền cụ thể trên bảng***

```
-- Cho phép xem và thêm khách hàng, đơn hàng
GRANT SELECT, INSERT ON dbo.KhachHang TO NhanVien1;
GRANT SELECT, INSERT ON dbo.DonHang TO NhanVien1;
 -- Chỉ cho phép xem sản phẩm, không được sửa/xóa
GRANT SELECT ON dbo.SanPham TO NhanVien1;
```

4. Gán và gỡ bỏ quyền (GRANT / REVOKE / DENY)

- ***Bước 4 – Dùng WITH GRANT OPTION***

  Nếu muốn NhanVien1 có thể cấp lại quyền SELECT trên bảng SanPham cho người khác (ví dụ nhân viên thực tập), ta thêm WITH GRANT OPTION:

  GRANT SELECT ON dbo.SanPham TO NhanVien1 WITH GRANT OPTION;

- ***Bước 5 – Cấm tường minh một quyền***

  Dù NhanVien1 thuộc một role có quyền DELETE trên DonHang, ta muốn cấm riêng NhanVien1 không được xóa đơn hàng:

  DENY DELETE ON dbo.DonHang TO NhanVien1;

- ***Bước 6 – Gỡ bỏ quyền***

  -- Gỡ quyền INSERT đã cấp trước đó

  REVOKE INSERT ON dbo.KhachHang FROM NhanVien1;

  -- Gỡ luôn lệnh DENY đã áp trước đó (đưa quyền DELETE về trạng thái trung lập)

  REVOKE DELETE ON dbo.DonHang FROM NhanVien1;

4. Gán và gỡ bỏ quyền (GRANT / REVOKE / DENY)

- **Kiểm tra quyền hiện có**

```
-- Xem quyền hiệu lực của user hiện tại trên 1 đối tượng
SELECT * FROM fn_my_permissions('dbo.KhachHang', 'OBJECT');
-- Xem toàn bộ quyền đã cấp trong database
SELECT grantee_principal_id, permission_name, state_desc, class_desc
FROM sys.database_permissions;
```

- **Gán quyền ở mức cột (Column-level permission):**
  - SQL Server cho phép giới hạn quyền đến từng cột, hữu ích khi cần che giấu thông tin nhạy cảm như lương, số điện thoại:

```
-- Chỉ cho phép xem 2 cột, không cho xem cột Luong
GRANT SELECT ON dbo.NhanVien (MaNV, HoTen) TO NhanVien1;
DENY SELECT ON dbo.NhanVien (Luong) TO NhanVien1;
```

5. Gán và gỡ bỏ quyền trên View

5. Gán và gỡ bỏ quyền trên View

- **Vì sao dùng View để bảo mật???**
- View là một "bảng ảo" được định nghĩa bằng câu truy vấn SELECT. View là công cụ bảo mật rất mạnh vì cho phép:
  - Giới hạn theo chiều dọc (vertical restriction): chỉ hiển thị một số cột nhất định (ẩn cột nhạy cảm như lương, CMND/CCCD).
  - Giới hạn theo chiều ngang (horizontal restriction): chỉ hiển thị một số dòng dữ liệu thỏa điều kiện (ví dụ nhân viên chỉ xem đơn hàng thuộc khu vực mình quản lý).
  - Ẩn cấu trúc thật của bảng gốc, giảm rủi ro khi cấu trúc bảng thay đổi.
  - Kết hợp/tổng hợp dữ liệu từ nhiều bảng nhưng chỉ hiển thị kết quả cần thiết, không lộ toàn bộ bảng nguồn.

5. Gán và gỡ bỏ quyền trên View

Ví dụ tạo View phục vụ bảo mật

- ***Giới hạn cột (ẩn cột Luong)***
  - CREATE VIEW dbo.vw_NhanVien_CongKhai
  - AS
  - SELECT MaNV, HoTen, PhongBan, NgayVaoLam
  - FROM dbo.NhanVien;
- ***Giới hạn dòng (chỉ xem đơn hàng của khu vực mình)***
  - CREATE VIEW dbo.vw_DonHang_MienBac
  - AS
  - SELECT * FROM dbo.DonHang
  - WHERE KhuVuc = N'Mien Bac';

5. Gán và gỡ bỏ quyền trên View

Gán quyền trên View

- Sau khi tạo View, ta GRANT quyền trên View giống như trên bảng, đồng thời có thể (và nên) REVOKE/không cấp quyền trực tiếp trên bảng gốc để người dùng bắt buộc phải truy cập qua View:

```
-- Cấp quyền xem trên view (không cấp quyền trực tiếp trên bảng NhanVien)
GRANT SELECT ON dbo.vw_NhanVien_CongKhai TO NhanVien1;


-- Đảm bảo NhanVien1 không có quyền truy cập trực tiếp bảng gốc
REVOKE SELECT ON dbo.NhanVien FROM NhanVien1;
```

5. Gán và gỡ bỏ quyền trên View

WITH CHECK OPTION

- Khi cho phép INSERT/UPDATE qua View có điều kiện lọc (WHERE), nên thêm WITH CHECK OPTION để đảm bảo dữ liệu ghi vào vẫn thỏa điều kiện của View, tránh trường hợp người dùng chèn/sửa dữ liệu "ra ngoài phạm vi" họ được phép thấy:

```
CREATE VIEW dbo.vw_DonHang_MienBac
AS
SELECT * FROM dbo.DonHang
WHERE KhuVuc = N'Mien Bac'
WITH CHECK OPTION;


GRANT SELECT, INSERT, UPDATE ON dbo.vw_DonHang_MienBac TO NhanVien1;
```

- Nếu không có WITH CHECK OPTION, NhanVien1 có thể INSERT một đơn hàng với KhuVuc = 'Mien Nam' thông qua view (dòng đó sẽ "biến mất" khỏi view do không còn thỏa điều kiện WHERE, nhưng vẫn tồn tại trong bảng gốc). Có WITH CHECK OPTION, SQL Server sẽ báo lỗi và từ chối thao tác đó.

5. Gán và gỡ bỏ quyền trên View

- **Gỡ bỏ quyền trên View**

```
REVOKE SELECT, INSERT, UPDATE ON dbo.vw_DonHang_MienBac
FROM NhanVien1;


-- Nếu muốn xóa hẳn view
DROP VIEW dbo.vw_DonHang_MienBac;
```

6. Phân quyền dựa trên Role (Role-Based Authorization)

6. Phân quyền dựa trên Role (Role-Based Authorization)

- **Vì sao cần Role???**
- Nếu cấp quyền trực tiếp cho từng user, khi số lượng người dùng lớn, việc quản lý sẽ rất phức tạp và dễ sai sót (ví dụ quên thu hồi quyền khi nhân viên nghỉ việc, cấp thiếu/thừa quyền). Role cho phép nhóm các quyền lại thành một "gói" gán cho nhiều user cùng chức năng, giúp:
  - Quản lý quyền tập trung, nhất quán theo chức danh/phòng ban.
  - Thêm/xóa user khỏi hệ thống chỉ cần thêm/xóa khỏi Role, không cần cấp lại từng quyền.
  - Dễ kiểm tra, đối soát (audit) ai đang có quyền gì thông qua việc xem thành viên của Role.

6. Phân quyền dựa trên Role (Role-Based Authorization)

- **Fixed Server Roles (Vai trò cấp Server có sẵn)**

Server Role	Quyền hạn
sysadmin	Toàn quyền trên toàn bộ SQL Server instance
securityadmin	Quản lý login và quyền GRANT/DENY/REVOKE ở mức server
dbcreator	Tạo, sửa, xóa, phục hồi database
diskadmin	Quản lý file đĩa của SQL Server
processadmin	Quản lý các tiến trình đang chạy trên SQL Server
public	Vai trò mặc định mọi login đều thuộc về, quyền tối thiểu

6. Phân quyền dựa trên Role (Role-Based Authorization)

- **Fixed Database Roles (Vai trò cấp Database có sẵn)**

Database Role	Quyền hạn
db_owner	Toàn quyền trên database (như chủ sở hữu)
db_datareader	Được SELECT trên mọi bảng trong database
db_datawriter	Được INSERT, UPDATE, DELETE trên mọi bảng
db_ddladmin	Được chạy các lệnh DDL (CREATE, ALTER, DROP) trên database
db_securityadmin	Quản lý quyền và thành viên role ở mức database
db_denydatareader	Cấm SELECT trên mọi bảng (ưu tiên cao, dùng để chặn nhanh)
db_denydatawriter	Cấm INSERT/UPDATE/DELETE trên mọi bảng

6. Phân quyền dựa trên Role (Role-Based Authorization)

Tạo Role tự định nghĩa (User-Defined Database Role)

- Trong thực tế, ta thường tự tạo role theo đúng nghiệp vụ của tổ chức thay vì chỉ dùng role có sẵn. Ví dụ tạo 3 role: NhanVienBanHang, QuanLyKho, KeToan.
- ***Bước 1 – Tạo Role***
  - USE QuanLyBanHang;
  - CREATE ROLE NhanVienBanHang AUTHORIZATION dbo;
  - CREATE ROLE QuanLyKho AUTHORIZATION dbo;
  - CREATE ROLE KeToan AUTHORIZATION dbo;

6. Phân quyền dựa trên Role (Role-Based Authorization)

Tạo Role tự định nghĩa (User-Defined Database Role)

- ***Bước 2 – Gán quyền cho Role (thay vì gán trực tiếp cho từng user)***

```
-- Role Nhân viên bán hàng
GRANT SELECT, INSERT ON dbo.DonHang TO NhanVienBanHang;
GRANT SELECT ON dbo.SanPham TO NhanVienBanHang;
GRANT SELECT, INSERT, UPDATE ON dbo.KhachHang TO NhanVienBanHang;
-- Role Quản lý kho
GRANT SELECT, INSERT, UPDATE, DELETE ON dbo.SanPham TO QuanLyKho;
GRANT SELECT ON dbo.DonHang TO QuanLyKho;
-- Role Kế toán
GRANT SELECT ON dbo.DonHang TO KeToan;
GRANT SELECT ON dbo.KhachHang TO KeToan;
DENY DELETE ON dbo.DonHang TO KeToan;
```

6. Phân quyền dựa trên Role (Role-Based Authorization)

Tạo Role tự định nghĩa (User-Defined Database Role)

- ***Bước 3 – Thêm user vào Role***

```
ALTER ROLE NhanVienBanHang ADD MEMBER NhanVien1;
ALTER ROLE NhanVienBanHang ADD MEMBER NhanVien2;
ALTER ROLE KeToan ADD MEMBER NhanVien3;
-- (Cú pháp cũ, tương đương, dùng trong các phiên bản trước SQL Server 2012)
-- EXEC sp_addrolemember 'NhanVienBanHang', 'NhanVien1';
```

- ***Bước 4 – Gỡ user khỏi Role / Xóa Role***

```
-- Gỡ 1 user khỏi role (ví dụ nhân viên chuyển bộ phận)
ALTER ROLE NhanVienBanHang DROP MEMBER NhanVien2;
-- Xóa hẳn role (chỉ xóa được khi role không còn thành viên và không sở hữu đối tượng nào)
DROP ROLE QuanLyKho;
```

6. Phân quyền dựa trên Role (Role-Based Authorization)

- Kiểm tra thành viên của Role:

-- Danh sách thành viên của 1 role

```
SELECT r.name AS RoleName, m.name AS MemberName
FROM sys.database_role_members drm
JOIN sys.database_principals r ON drm.role_principal_id = r.principal_id
JOIN sys.database_principals m ON drm.member_principal_id = m.principal_id
WHERE r.name = 'NhanVienBanHang';
```

6. Phân quyền dựa trên Role (Role-Based Authorization)

- Application Role (Vai trò ứng dụng)
  - Là loại role đặc biệt, không chứa thành viên cố định; ứng dụng sẽ "kích hoạt" role này bằng mật khẩu riêng khi kết nối, giúp kiểm soát quyền theo ứng dụng thay vì theo từng người dùng cuối:

```
CREATE APPLICATION ROLE AppBanHang WITH PASSWORD = 'App@2026', DEFAULT_SCHEMA = dbo;
GRANT SELECT, INSERT, UPDATE ON dbo.DonHang TO AppBanHang;
 -- Trong tầng ứng dụng, khi kết nối:
EXEC sp_setapprole 'AppBanHang', 'App@2026';
```

6. Phân quyền dựa trên Role (Role-Based Authorization)

- So sánh cấp quyền trực tiếp và cấp qua Role:

Tiêu chí	Cấp trực tiếp cho User	Cấp qua Role
Số lệnh cần khi có 100 user	Rất nhiều (nhân theo số user)	Ít (chỉ cần thêm user vào role có sẵn)
Khi nhân viên đổi vị trí	Phải rà soát, sửa từng quyền	Chỉ cần đổi role thành viên
Khả năng kiểm toán (audit)	Khó, phải kiểm từng user	Dễ, chỉ cần xem danh sách role
Rủi ro sai sót	Cao	Thấp hơn nhiều

- **Khuyến nghị thực tế**
  - Trong hệ thống thực tế, nên ưu tiên: (1) không GRANT quyền trực tiếp cho user cá nhân trừ trường hợp đặc biệt; (2) thiết kế Role theo chức năng nghiệp vụ; (3) dùng View để giới hạn dữ liệu nhạy cảm; (4) kết hợp DENY để chặn nhanh các trường hợp ngoại lệ; (5) định kỳ audit thành viên Role và quyền đã cấp.

7. Bài tập

7. Bài tập

- **Bài 1.** Cho lược đồ CSDL Truong_Hoc gồm các bảng: SinhVien(MaSV, HoTen, Lop, DiemTB, SDT), GiaoVien(MaGV, HoTen, Khoa), MonHoc(MaMH, TenMH, MaGV), KetQua(MaSV, MaMH, Diem).
  1. Tạo Login và User cho một giáo viên tên GiaoVien_A, cho phép người này SELECT trên bảng MonHoc và KetQua, nhưng chỉ được UPDATE cột Diem trong bảng KetQua đối với các môn do chính mình phụ trách.
  2. Tạo một View tên vw_KetQua_CongKhai chỉ hiển thị MaSV, TenMH, Diem (ẩn SDT của sinh viên) và cấp quyền SELECT trên view này cho toàn bộ role SinhVien.
  3. Tạo Role PhongDaoTao có quyền SELECT, INSERT, UPDATE, DELETE trên toàn bộ 4 bảng; sau đó thêm 2 user NhanVien_A, NhanVien_B vào role này bằng ALTER ROLE.
  4. Viết lệnh DENY để đảm bảo dù thuộc role PhongDaoTao, user NhanVien_B vẫn không được phép DELETE trên bảng KetQua (ví dụ do đang trong thời gian thử việc).
  5. Viết lệnh REVOKE để gỡ bỏ hoàn toàn quyền UPDATE trên bảng SinhVien đã cấp cho GiaoVien_A ở câu 1.
  6. Tạo View vw_SinhVien_LopA chỉ hiển thị sinh viên thuộc Lop = 'CNTT-K20', có WITH CHECK OPTION, và giải thích điều gì sẽ xảy ra nếu một user INSERT một sinh viên với Lop khác qua view này.

7. Bài tập

- **Bài 2.** Một công ty có 3 phòng ban: Kinh doanh, Kế toán, Nhân sự, mỗi phòng có 10-15 nhân viên.
- Yêu cầu:
  - nhân viên Kinh doanh chỉ được xem/sửa dữ liệu khách hàng và đơn hàng;
  - nhân viên Kế toán chỉ được xem đơn hàng và không được sửa/xóa;
  - nhân viên Nhân sự được toàn quyền trên bảng lương nhưng các phòng khác tuyệt đối không được xem cột lương.
- Hãy thiết kế:
  1. Danh sách Role cần tạo.
  2. Quyền tương ứng cho từng Role.
  3. Có cần dùng View để ẩn cột lương không. Vì sao?
  4. Viết các lệnh T-SQL (CREATE ROLE, GRANT, DENY, ALTER ROLE ADD MEMBER) để hiện thực hóa thiết kế trên.

Tài liệu tham khảo

- Raghu Ramarkrishnan, Johannes Gehrke. *Database Management System*. 3rd Edition, Mc Graw Hill, 2003.
- Tutorials Point, Database Management System, www.tutorialspoint.com, 2015.
- Hector Garcia-Molina, Jeffrey D. Ullman and Jennifer Widom. *Database Systems, the Complete Book*, 2nd Edition, Prentice Hall, 2009
- Ramez Elmasri, Shamkant B. Navathe. *Fundamentals of Database Systems*. *7th Edition*, Pearson, 2015
- Silberschatz,Korth and Sudarshan, Database System Concepts (6th Edition), McGraw-Hill, 2010.

Hết!
Cảm ơn Anh/ Chị đã theo dõi!

GVHD: TS. Phan Thị Thể

FIT – HCM-UTE

Email: thept@hcmute.edu.vn